

Old McDonald Had A Barcode...

E-I E-I CAR

RICHARD HENDERSON

DEF CON 29 – Las Vegas, NV USA – August 2021



Who Am I?

Richard:

Ham/electronics nerd, writer, infosec professional. DEF
CON trainer, contest runner.

@RichSentMe



Preface: What would happen if you built a system that is designed to accept barcode inputs but didn't do any input validation?



X50!P%@AP[4\pZX54(P^)7CC)7)\$EICAR-STANDARD-ANTIVIRUS-
TEST-FILE!\$H+H*

4083DEFDAFBF

General Error from Server
General Error from Server

What IS the EICAR string?



X5O!P%@AP[4\PZX54(P^)7CC)7}\$EICAR
-STANDARD-ANTIVIRUS-TEST-
FILE!\$H+H*

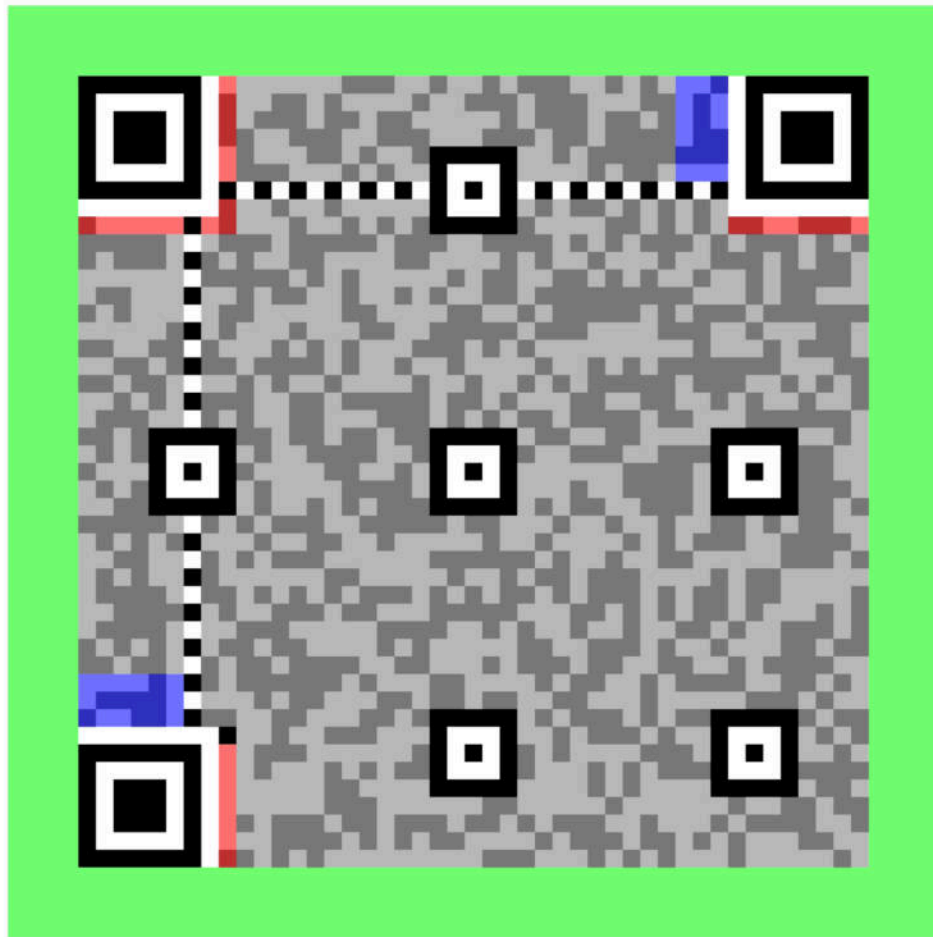


Who created it?
What is it used for?
How does it work?



QR Codes





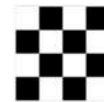
1. Version information



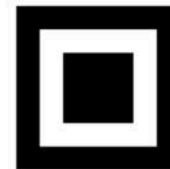
2. Format information



3. Data and error correction keys



4. Required patterns



4.1. Position



4.2. Alignment



4.3. Timing



5. Quiet zone



What would happen if you put the two together?



X50!P%@AP[4\pZX54(P^)^7CC)7)\$EICAR-STANDARD-ANTIVIRUS-
TEST-FILE!\$H+H*

4083DEFDAFBF

General Error from Server
General Error from Server

Where did this whole thing start?





Rob Rosenberger
@vmyths



Replying to @vmyths @c4i and @KimZetter

MEMO TO SELF:

Disable @Sophos Android app before I photograph the #EICAR #antivirus test string QR code 🙄



DEF CON

**Beyond a sticker on your car, what
else could you do?**





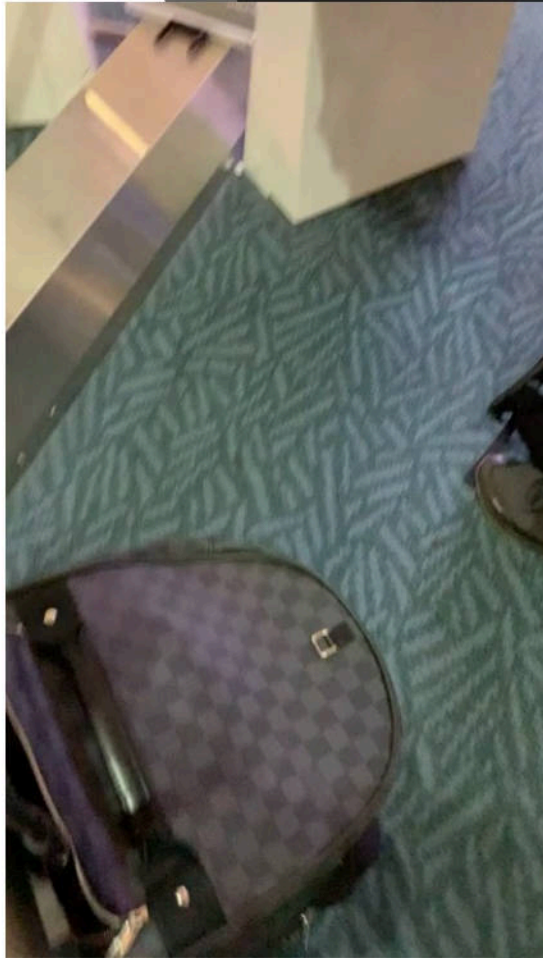
DEFCON

X50!P%@AP[4\pZX54(P^)7CC)7)\$EICAR-STANDARD-ANTIVIRUS-
TEST-FILE!\$H+H*

4083DEFDAFBF

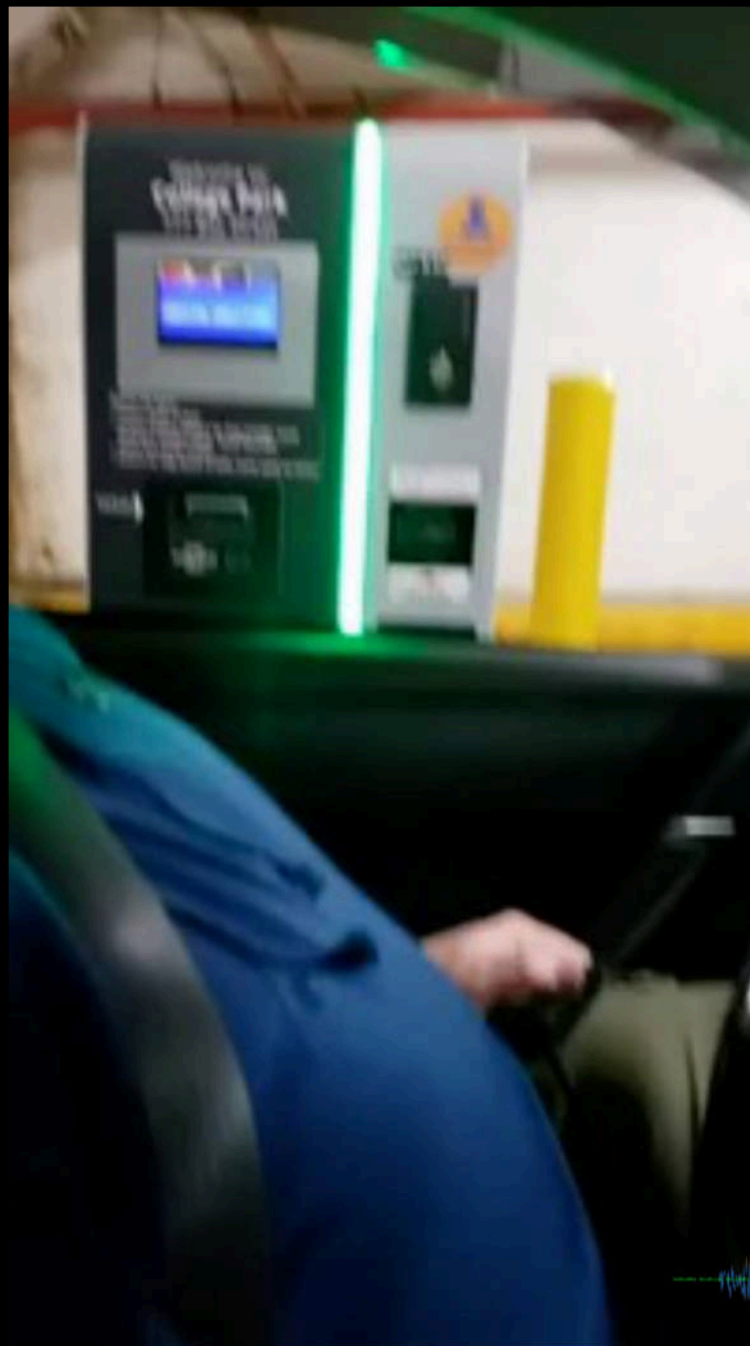
General Error from Server General Error from Server

DEF CON



- This video was sent to me by a random friend... I would never do something stupid like this.
- This is a passport scanner at a port of entry
- Many countries now offer people entering a smartphone app to digitally fill out their customs entry card... and that app creates a QR code that the passport machines can read...











So what happened here?



Why does this “attack” work?



Much like ICS and SCADA where companies just "bolted-on" internet connectivity with zero thoughts of the security implications of doing so, companies are making devices "smart" and not really thinking very much about how people might be able to fuck with them.



**Most of these “smart” machines are
all running Windows or Windows
Embedded underneath.**



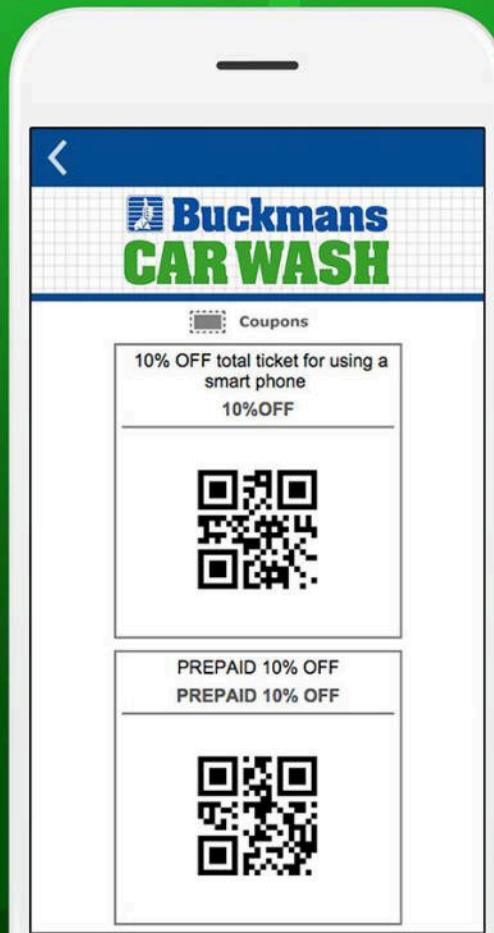
**Why are devices and systems
scanning QR codes anyway?**



**What other things might you be able
to scan???**



Lookup Current *Promotions and Coupons*



Price Scanner

Scan for Price



DEFCON

[Printers](#)[Cash Drawers](#)[Barcode Scanners](#)[Consumables](#)[POS Bundles](#)[POS Systems](#)[iPad / Tablet Stands](#)[Office Equipments](#)[Computers](#)[Home](#) / [Barcode Scanners](#) / [Discontinued Products](#) / Honeywell IK8570 Price Checker & Interactive Kiosk Barcode Scanner

Honeywell IK8570 Price Checker & Interactive Kiosk Barcode Scanner

\$2,995.00

(Inc GST)

For Special & Volume Pricing - Call 0291 919 694

CODE: IK8570

Quantity:

ADD TO CART

Need Assistance
choosing a product

☎ 1300 590 094

💬 Live Chat

✉ sales@poscentral.com.au

Our product expert team

Description

Discontinued

The Image Kiosk 8570 are designed to give customers instant self-access to information they need. Offering a range of functionality including price checking, item information look-up, and loyalty program administration, Image Kiosks give you the ability to assist and communicate with your customers effectively and efficiently – all without requiring them to seek out an employee.

DEFCON

- ✓ Small footprint, taking up minimum floor space
- ✓ Customer-Safe Scanning Technology
- ✓ High Performance Intel® XScale® processor
- ✓ Fast and intuitive bar code reading of all linear and 2D bar codes
- ✓ Finger-touch navigation
- ✓ Integrated Magnetic Stripe Reader (IK8570 only)
- ✓ Powerful integrated software tools for simplified configuration and application development

Attachments

Honeywell IK8570-Brochure (ik8560_8570.pdf, 217 Kb) [[Download](#)]

Specifications

Processor	Intel® XScale® PXA255 200 Mhz
Operating Platform	Microsoft Windows CE 5.0
Memory	IK8570 Models 64Mb FlashROM x 64Mb SDRAM onboard memory



VI MonitorPlus

Administrator

Workspaces Modules System Administration Help

Q Search

LPR Monitoring

Servers

VI Transportation 1

WV-X6531 (VID)

X4171

WV-SFV481 (15fps/SmartC

WV-SFV481 (10fps/Normal

P-24 Corridor

P-24

SFV781

SI131L

Aaro PTZ-test

Panasonic V

Axis M3007

Samsung SNF-7010V

BWC

BWC 51

LPR camera

LPR camera 2

OPTEX

S4550L

Sample NVR

Live Cameras

☒ LPR camera

☒ LPR camera 2

Select All





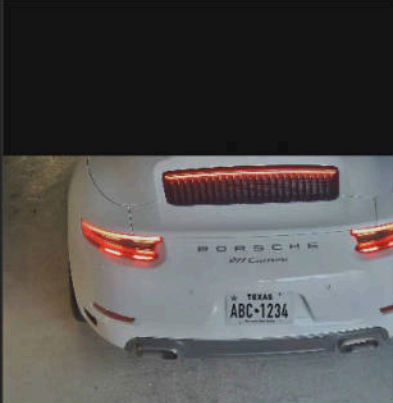
Event Details

Event Time

5/1/2018 9:04:00 PM

Camera

LPR camera 2



View Event Video

5 + - seconds before event

Plate

License Plate

ABC1234

Country/State

Plate Type

Plate Color

Color [Transparent]

Confidence Level

94%

Save License Plate

Events

EVENT TIME	CAMERA NAME	LICENSE PLATE	PLATE TYPE	PLATE COLOR	COUNTRY/STATE	KNOWN PLATE	YEAR	MAKE	MODEL	COLOR	FIRST NAME	LAST NAME	THREAT LEVEL
5/1/2018 9:04:00 PM	LPR camera 2	ABC1234		Color [Transparent]		☐							
5/1/2018 9:03:49 PM	LPR camera 2	ABC4321		Color [Transparent]		☐							
5/1/2018 9:03:49 PM	LPR camera	ABC1111		Color [Transparent]	USA-TX	☒	2020	Honda	Accord	Blue	Hiro	Kitaoka	None123
5/1/2018 9:03:48 PM	LPR camera 2	ABC2222		Color [Transparent]		☐							
5/1/2018 9:03:12 PM	LPR camera 2	ABC3333		Color [Transparent]		☐							
5/1/2018 9:02:52 PM	LPR camera 2	ABC4444		Color [Transparent]		☐							
5/1/2018 9:02:51 PM	LPR camera 2	CBA1234		Color [Transparent]		☐							

Pause Events

Clear Events

☒ Keep latest event selected

Clear Selection

Cameras

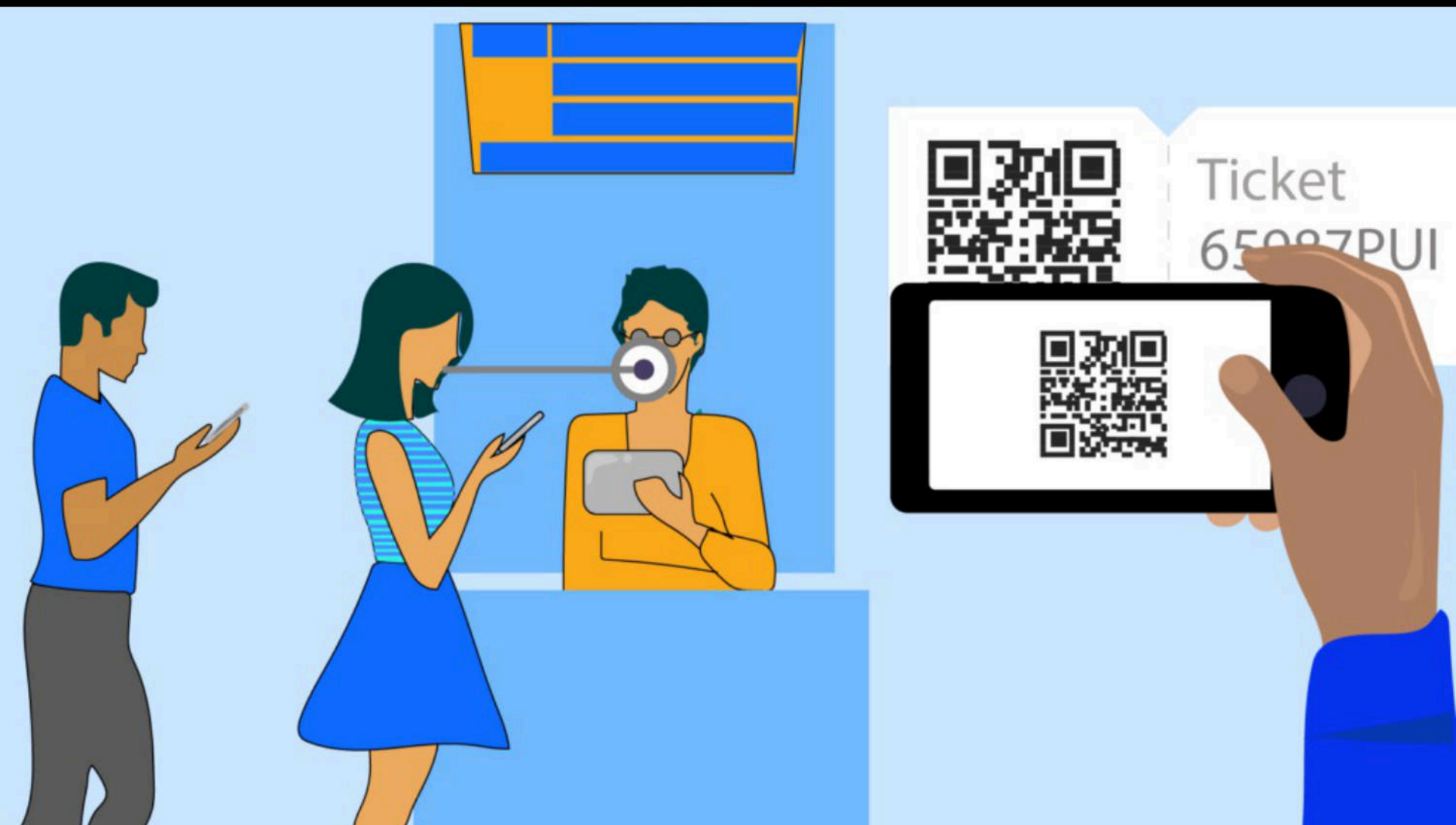
Views

Maps



**Amazingly, I have yet to be able to
find a parking enforcement officer
willing to let me try (lol)**











Extensions of this “attack”



There are a lot of 2D barcode types out there... try and figure out which ones your target is using.



Data Matrix



Aztec



MaxiCode



MicroPDF417



Han Xin



**Could you take some malicious JS
and have a system parse it?**

**Or just something as simple as
sending someone to a malicious
URL...**





Credit: appsec-labs

**What other systems might you be
able to attack?**



**What would happen if you encode
EICAR into an RFID tag?**



**ATMs often use Windows
underneath...**



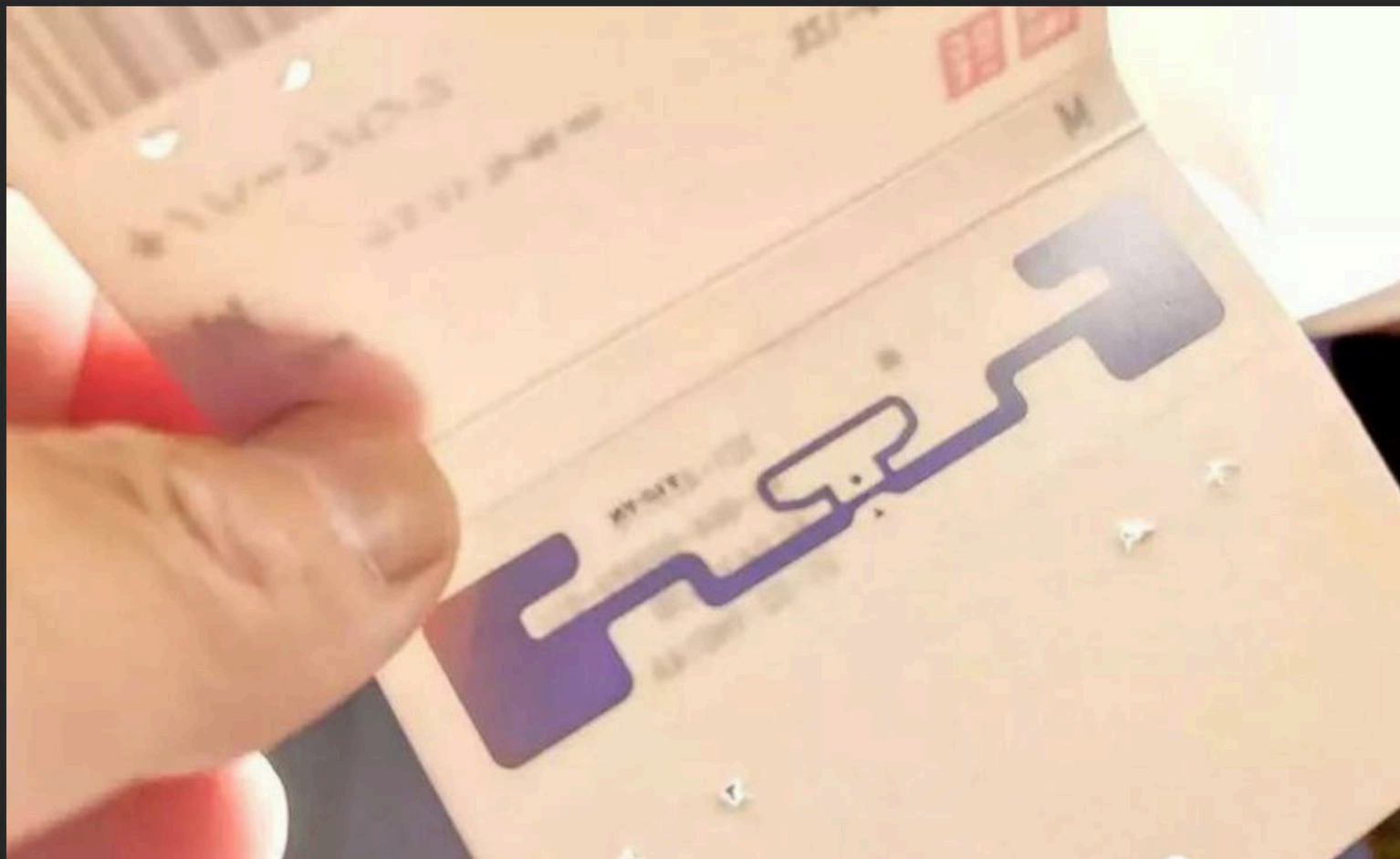
Some railroads use RFID tags on cargo containers to track the movement of cargo containers... and have for more than 20 years.



**A whole bunch of retailers are using
RFID tags now to combat theft and
to make checking out way faster:**

- Uniqlo**
- H&M**
- Zara**
- etc.**







BS0138TE-JP

25-27cm

09 Black



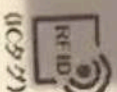
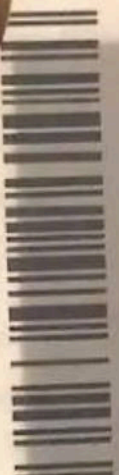
綿
アクリル
ナイロン
ポリエステル
ポリウレタン

59%
25%
12%
2%

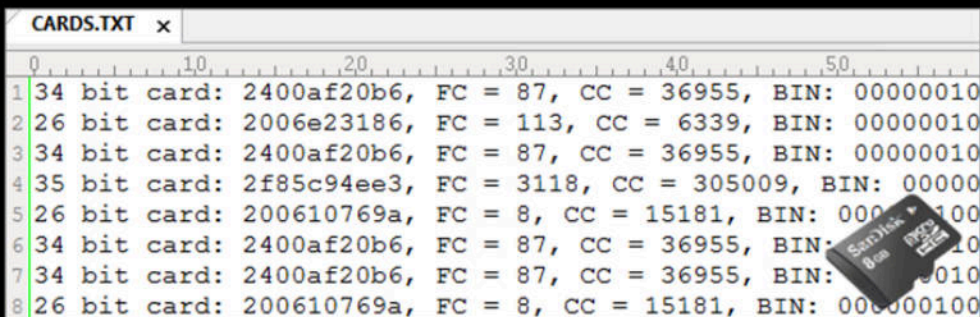
371-400677
09-025-00079-16)

207-020A-64E
01-37-7F110B
ME97

(株) ユニクロ
〒754-0894 山口県山口市佐山717-1
タイ製



0102956326



DEFCON



**You can buy just about anything on
AliExpress... or Amazon these days.**



Is this shit legal?

IANAL.



But what IS the legality of walking around with a giant barcode on your backpack causing random camera systems to crash?

You didn't give them permission to scan it... and shouldn't they have input validation anyway?



Want to try it out?

Stickermule is a great site to do small runs of stickers cheaply, but there are dozens others.

Laser labels at home work great.



Embroidered patches:

**Google it. You'll find it. Not going to
shill my site here.**

**If you're at DEF CON in person, come
on up and get a patch for free.**



Questions?



**Did you try this out and find
something interesting?**

**LET ME KNOW:
richard@goatse.cx (yes, really)**



THANK YOU!

